

ACTIVITY PACK

Activity 5: Discussion Questions

Activity 5 - Agent Governance and the Deployment Gate

Course	AI Security for Autonomous AI Agents
Course code	TGS-2025060473
Version	3.0 20 August 2026

Tertiary Infotech Pte Ltd | UEN 20120096W

Discussion Questions

Activity 5 - Discussion Questions

Agent Governance and the Deployment Gate

You are the AI Governance Board. Work through all five questions and produce the four deliverables named in the scenario. Nominate one person to deliver the board's decision - three minutes, no slides, as you would to a Board of Directors. You have 25 minutes.

This is the capstone. Everything from the previous four activities is in scope: trust boundaries, prompt injection, poisoning, framework selection, agent architecture and excessive agency.

Q1 - Read the evaluation results as a governance board, not as a data scientist (A1)

The model risk lead recommends proceeding on the strength of 91.2% aggregate accuracy.

- Explain what the **segment table** shows that the aggregate figure conceals, and quantify the gap between the best-served and worst-served segments on **both** accuracy and false escalation rate.

- The false "escalate to recovery agency" rate is **7.8% for Work Permit / S Pass holders** against

1.2% for the baseline segment. Translate that into **people per year** at the bank's volume, and describe what actually happens to one of those people.

- The lead attributes the variance to "training data distribution and case-mix differences." Assess that explanation. Does identifying a cause discharge the bank's responsibility for the effect?

- State whether an aggregate accuracy threshold is a **fit-for-purpose governance control** for a system that acts on individuals, and say what you would replace or supplement it with.

Q2 - Hallucination as a security control failure, not a quality issue (A1)

ARIA hallucinates on **4.7%** of cases, and **38%** of those hallucinations result in a **wrong tool call being executed**.

- Compute the effective rate of wrong executed actions per 1,000 cases, and per year at 31,000 cases.

State what that number means when the tool in question is *escalate to the debt recovery agency* or *submit a credit bureau data point*.

- OWASP treats **misinformation** as an application-security risk rather than only a quality issue.

Justify that treatment using ARIA specifically. Why is a hallucination that drives a tool call categorically different from one that produces a wrong sentence?

- The evaluation logged 11 instances of ARIA importing **non-existent Python packages**, two of which

a developer attempted to install. Name this failure mode using its OWASP 2026 identifier and title, explain the attack it invites, and say why "minor code quality issue" is the wrong severity.

- Identify **three limitations** of ARIA that are not solved solely by adding more training data, and

explain what each one implies for the autonomy you are willing to grant.

Q3 - Discharge the PDPA and PDPC obligations (A2)

Meridian Bank operates the deployment and, using the PDPC's 2 June 2026 proposed consultation vocabulary, is the **system deployer**.

- Under the current PDPA obligations, explain what it means for the deploying organisation to retain

its own statutory duties in practice, and why a vendor's reputation or contractual assurances do not transfer those duties. You may use the PDPC's 2 June 2026 proposed GenAI consultation text as a labelled proposal, not as final law or final guidance.

- Assess the drafted notice - **"We may use automated systems and new technologies to improve our**

products and services" - against the guidelines' consent and notification requirements. Rewrite it so it would survive scrutiny, and state what it must disclose that the current wording omits.

- The proposed consultation text highlights **new data surfaces**: end-user prompts, generated outputs, ****agent** and tool

activity data**, and internal enterprise data. Identify every such surface ARIA creates, say who holds it and where, and flag the ones the bank has not inventoried.

- ARIA's per-customer memory is retained indefinitely. Address this against **retention limitation**

and the access-and-correction obligations. What does a customer's correction request even mean once a wrong belief is embedded in agent memory and has already influenced three conversations?

Q4 - Apply the IMDA agentic governance framework (A2)

IMDA's Model AI Governance Framework for Agentic AI (January 2026, updated June 2026) sets out four dimensions: **risk assessment, human accountability, technical controls, and end-user responsibility**.

- Work ARIA through IMDA's autonomy calibration: **impact** (domain sensitivity, data access, action

scope) x **likelihood** (autonomy level, task complexity, third-party dependencies). Show your reasoning, and place ARIA on the resulting scale.

- Define the **human approval checkpoints** IMDA requires for "higher-risk or irreversible actions."

Go through ARIA's ten capabilities and defend where you place each. Say explicitly which capabilities you judge **unsuitable for an agent entirely** - IMDA states plainly that some use cases are.

- IMDA prefers **structural, system-level technical controls over prompt-based ones**. Give two

controls the board should require for ARIA that satisfy this preference, and contrast each with the prompt-based version a project team would propose instead.

- IMDA requires auditing **override rates and response times**. The bank's audit trail cannot

currently distinguish ARIA's actions from an officer's. Explain why that single gap undermines the entire accountability dimension, and specify what must change.

Q5 - Decide, and own the societal consequence (A2, A1)

Deliver your board decision.

- State **go / no-go / go-with-conditions**, and make every condition **testable** - a condition that

cannot be failed is not a condition.

- Set out your **human accountability model**: the named accountable role, the approval checkpoints,

the override path, and the customer's route to challenge an ARIA decision and reach a human. Say how the bank satisfies IMDA's **end-user responsibility** dimension - what customers and officers are told about ARIA's capabilities, data access and escalation route.

- Confront the ethical and societal argument on both sides. Rachel Tay is right that the status quo

leaves distressed customers waiting nine days, and that S\$117,000 a week is a stated synthetic business-case cost.

Your controls will slow ARIA down. Justify your position **in terms of who bears the cost of each choice** - and note which groups bear the cost of a false escalation and which bear the cost of a delayed deployment. They are not the same people.

- A director wants ARIA extended to **SME credit decisioning** next year. Give the board your position

now, with reasons, before the momentum makes it undiscussable.